Incident Report: Suspicious Authentication Activity

Student portal authentication log - reconstructed from a synthetic training dataset

Log period	2026-08-01T09:00:12Z to 2026-08-01T11:47:09Z (2 h 46 min 57 s)
Source	authentication-log-sample.csv (12 events, EdVyro task source library)
Environment	Fictional student portal; documentation IP ranges (RFC 5737). No external system was scanned or contacted.
Status	Findings open: verification of F3 and review of F2 targets pending

1. Executive summary

The log shows three separate threads. A **password-spraying attempt** (F2) hit four accounts from one IP within 12 seconds and was rate-limited; no successful login from that IP is visible. Two hours later one of those four accounts, **stu-311, logged in successfully from a new IP and device** (F3). This may be the owner on a new phone or an account takeover, and the log alone cannot decide. A third thread, **three failed logins and a lockout on stu-117** (F1), looks like an ordinary user mistake. **The first action is to verify the stu-311 login with its owner.**

ID	Finding	Classification	Confidence	Risk
F1	Three failed logins then lockout on stu-117	Likely user mistake (targeted guessing not excluded)	Medium	Low
F2	Password spraying from 203.0.113.42	Suspicious: credential spraying pattern	High	High
F3	Possible account takeover: stu-311 login from a new IP and device	Unconfirmed: needs verification with the account owner	Low-Medium	High (provisional)

Immediate actions (P1)

- Verify the stu-311 login at 11:47:09 with the owner through a trusted channel. If not confirmed: reset password, revoke sessions and refresh tokens, review activity after E12.
- Review wider logs for stu-209, stu-415 and stu-502 for successful logins or password changes since 09:21 and notify the owners.
- Confirm whether the 09:22:01 block (E10) covers the whole IP or only stu-209; block or challenge 203.0.113.42 if it does not.

2. Scope, data and method

The task was to establish a baseline, find clusters of failures, separate likely user mistakes from suspicious patterns, build a timeline and recommend detection and rate-limit controls. All analysis is reproducible with **src/investigation.py**; the workbook **security-log-investigation.xlsx** holds the same results with live formulas.

Normalisation. Timestamps were parsed as ISO-8601 and converted to UTC datetimes; IPs were validated and labelled with their documentation range and /24 subnet; account IDs were trimmed and checked against the stu-NNN pattern; events were mapped to classes (authentication, session, control); results were kept raw and also mapped to an event-aware outcome; each row received an ID (E01-E12) so findings can cite evidence.

Data quality. 12 of 12 rows parsed; no missing values, duplicates or invalid IPs; all timestamps were already in order. Two notes matter for the analysis: (1) four rows have *device* = *unknown*, all from one IP, treated as a signal rather than missing data; (2) *success* on an account_lock event means the lock was applied, not that anyone logged in, so it is kept out of the login counts. No rows were removed.

3. Baseline

Metric	Value
Events / accounts / source IPs	12 / 6 / 4
Password logins	9 (7 failed, 2 successful)
Other events	1 token refresh, 1 account lock, 1 rate-limit block
Events by hour (UTC)	09:00: 10, 10:00: 1, 11:00: 1

Reference pattern. stu-104: password login 09:00:12 then token refresh 10:15:32, same IP 192.0.2.18 and device android. This is the only clean sequence in the log, and the rules below do not alert on it.
Caveat: 12 events cannot support a statistical baseline. The 78% failure rate is a product of the sample, not a norm. Thresholds are rule-of-thumb values and should be tuned on about 30 days of real data.

4. Detection rules

ID	Rule	Logic and threshold	Severity	Result on this log
R1	Brute force (one account)	Failed password logins for one account from any IP. Key: user_id. Window: 300 s. Threshold: >= 3 failures.	Medium; Low if single IP+device with human pacing; High at >= 10 failures or success after cluster	Fires: stu-117 (E02-E04)
R2	Password spraying (one IP)	Failures across several accounts from one IP, few attempts each. Key: source_ip. Window: 120 s. Threshold: >= 3 distinct accounts, <= 2 attempts per account.	High	Fires: 203.0.113.42 (E06-E09)
R3	Unusual access after exposure	Successful password login from an IP+device pair not seen for the account, with >= 1 failure for that account in the previous 24 h (any IP). Key: user_id. Window: 24 h look-back. Threshold: new pair AND >= 1 prior failure.	High (provisional)	Fires: E12 (stu-311)
R4	Control health	A lock or rate-limit event arrives later than the SLO after the threshold was crossed. Key: control event. Window: 10 s SLO (proposed). Threshold: latency > 10 s.	Medium	Fires: lock 45 s, rate limit 39 s

Each rule was also checked against the whole log: R1 fires only for stu-117, R2 only for 203.0.113.42, R3 only for E12, and nothing fires on stu-104. R4 uses a 10 s response target that I proposed; it is an assumption, not a measured standard.

5. Findings

F1. Three failed logins then lockout on stu-117

Classification	Likely user mistake (targeted guessing not excluded)
Evidence	3 password failures for stu-117 from 198.51.100.27 (device windows) in 34 s, gaps 17/17 s; account_lock applied 45 s after the 3rd failure. No success afterwards in this log.
Inference	Consistent device, one IP, one account and human-like pacing fit a forgotten or mistyped password. A slow, targeted guess cannot be ruled out from three events.
Confidence / risk	Medium confidence. Risk: Low. One account, contained by the lock, no sign of success: low likelihood of malice and low impact.
Action	Confirm the user recovered through a verified reset; watch stu-117 for further failures from other IPs.
Verification	No new failures/successes for stu-117 from unfamiliar IPs after unlock.

F2. Password spraying from 203.0.113.42

Classification	Suspicious: credential spraying pattern
Evidence	4 failures against 4 different accounts (stu-209, stu-311, stu-415, stu-502), one attempt each, from one IP with device 'unknown', gaps 3/4/5 s, 12 s in total. A rate_limit block followed 39 s after the last attempt (E10, on stu-209). No successful login from this IP appears in the log.
Inference	One attempt per account at machine pace, with no client identity, is the signature of automated spraying (trying one likely password across many accounts to stay under per-account lockouts). Intent: credential theft (assumed).
Confidence / risk	High confidence. Risk: High. Deliberate multi-account attack (high likelihood) against student accounts (medium impact); contained so far, but the scope of the block is unknown and a slower retry or a new IP would not be caught by it.
Action	Check the three other targets for successes; confirm whether E10 blocks the IP or only stu-209; block or challenge the IP.
Verification	Replay log: R2 fires once on 203.0.113.42; post-fix test shows a 5th account attempt from that IP is refused.

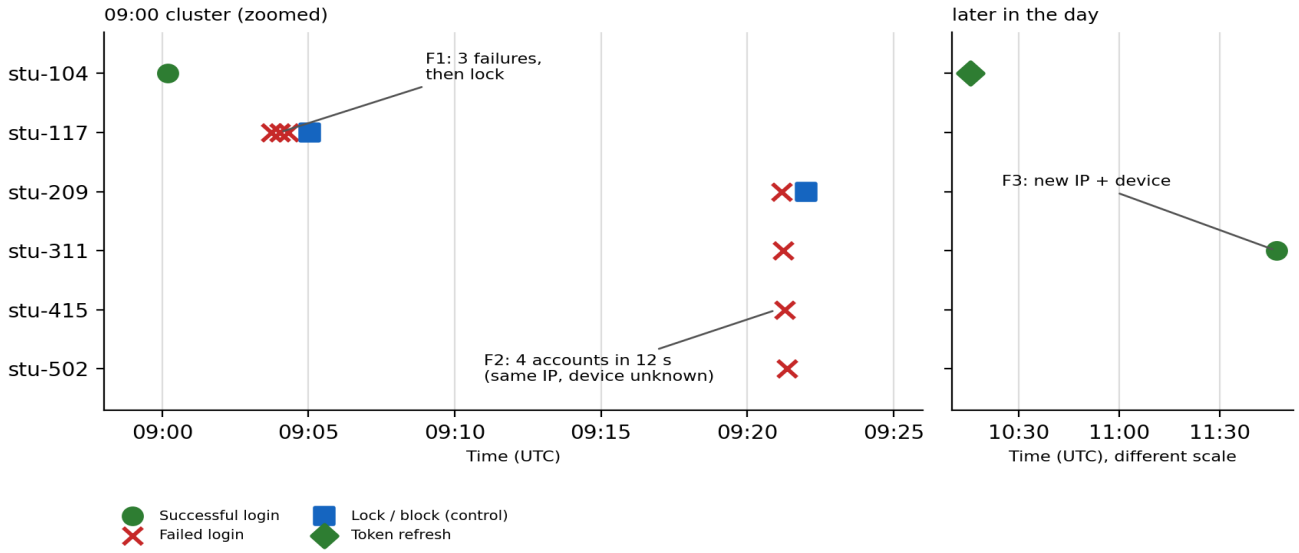
User mistake or suspicious? The two clusters compared

Signal	F1: stu-117	F2: 203.0.113.42
Accounts targeted	1 (stu-117)	4 (stu-209, 311, 415, 502)
Attempts per account	3	1 each
Source IPs	1 (198.51.100.27)	1 (203.0.113.42)
Device	windows (consistent, identified)	unknown on 4 of 4
Pacing	17/17 s gaps: human retyping is plausible	3/4/5 s gaps: faster than manual entry
Duration	34 s for 3 attempts	12 s for 4 attempts
Outcome	Lock applied; no success seen	Rate-limit block; no success from this IP
Reading	Likely user mistake (medium confidence)	Suspicious: spraying (high confidence)

F3. Possible account takeover: stu-311 login from a new IP and device

Classification	Unconfirmed: needs verification with the account owner
Evidence	stu-311 was a spray target (failed from 203.0.113.42 at 09:21:13, E07). 2 h 25 min 56 s later (11:47:09, E12) it logged in successfully from 192.0.2.99 on an ios device, an IP and device not previously seen for that account. 192.0.2.99 shares a /24 with stu-104's normal IP 192.0.2.18.
Inference	Could be the owner on a new phone (the shared /24 hints at a common network) or an attacker who guessed the password, possibly from another IP. The link to the spray is circumstantial: different IP, 2+ hours apart, no history for stu-311.
Confidence / risk	Low-Medium confidence. Risk: High (provisional). A success is the only event that gives an attacker access, so impact is high; likelihood is unproven. Rated High until verified because verification is cheap.
Action	Verify with the owner via a trusted channel; if not confirmed reset the password, revoke sessions and refresh tokens, review activity after E12.
Verification	Owner confirmation recorded; if reset, old session/refresh token rejected.

6. Timeline (UTC, 2026-08-01)



Time	Events	Evidence (log)	Interpretation	Conf.
09:00:12	E01	stu-104 password login succeeds from 192.0.2.18 (android).	Normal start of session; this IP+device becomes the known-good reference for stu-104.	High
09:03:44	E02-E04	3 failed logins for stu-117 from 198.51.100.27 (windows), gaps 17/17 s.	Probably a forgotten or mistyped password; targeted guessing not excluded.	Medium
09:05:03	E05	account_lock applied to stu-117, 45 s after the 3rd failure.	Lockout control works; the 45 s lag is a delay worth tightening.	High
09:21:10	E06-E09	4 failures, 4 accounts, one IP (203.0.113.42), device unknown, gaps 3/4/5 s.	Password-spraying pattern: automated, one attempt per account.	High
09:22:01	E10	rate_limit 'blocked' for stu-209 from 203.0.113.42, 39 s after the last attempt.	Control engaged; whether it blocks the IP or just the account is not shown.	Medium
10:15:32	E11	stu-104 refresh_token succeeds from 192.0.2.18 (android), 1 h 15 min after login.	Normal session continuation: same IP and device as E01.	High
11:47:09	E12	stu-311 password login succeeds from 192.0.2.99 (ios), 2 h 25 min 56 s after the spray failure.	Possible takeover or a legitimate new device: unconfirmed.	Low-Med

7. Evidence versus assumptions

Statements are labelled so a reader can see what the log proves and what is judgement.

ID	Statement	Type	Conf.	What would confirm or refute it
E-1	stu-117: 3 consecutive failures, one IP and device, 34 s, then account_lock (E02-E05).	Evidence	High	Log rows.
A-1	The stu-117 failures were the user's own mistakes.	Assumption	Medium	Confirm: user reset request after lock. Refute: failures for stu-117 from other IPs, or other accounts tried from 198.51.100.27.
E-2	4 different accounts failed once each from 203.0.113.42 within 12 s, device unknown (E06-E09).	Evidence	High	Log rows.
A-2	That burst was automated password spraying.	Assumption	High	Refute: the IP is a shared NAT/campus gateway with 4 users genuinely mistyping within 12 s (unlikely).
A-3	The spray aimed to steal credentials.	Assumption	Medium	Needs threat intel or a successful login to confirm.
E-3	rate_limit 'blocked' logged for stu-209 from 203.0.113.42 at 09:22:01 (E10).	Evidence	High	Log row.
U-1	Unknown: whether E10 blocks the IP or only the account.	Unknown	n/a	Check rate-limiter configuration/logs.
E-4	No successful login from 203.0.113.42 appears in this 2 h 47 min log.	Evidence	High	Limited to this log window and source.
A-4	None of the 4 spray targets was compromised by that IP.	Assumption	Medium	Check wider logs and password-change events.
E-5	stu-311 succeeded from 192.0.2.99/ios at 11:47:09 after a failure from 203.0.113.42 at 09:21:13 (E07, E12).	Evidence	High	Log rows.
A-5	The 11:47 login was made by an attacker.	Assumption	Low-Med	Confirm: owner denies it. Refute: owner confirms new phone/network. 192.0.2.99 shares a /24 with stu-104's IP.
A-6	The failed stu-311 attempt at 09:21:13 was the attacker, not the owner.	Assumption	Medium	Owner interview.
L-1	Limitation: the log has no logout, MFA, page-access or password-change events, so post-login impact is unknowable here.	Limitation	n/a	Collect richer logs.
L-2	Limitation: 12 events over 2 h 47 min cannot support a statistical baseline; thresholds are rule-of-thumb values to be tuned on 30 days of data.	Limitation	n/a	Re-run on a larger log.

8. Recommendations

P1 = do now, P2 = this sprint, P3 = backlog.

ID	Pri	Type	Action	For	Verification
A1	P1	Response	Verify the stu-311 login at 11:47:09 with the owner through a trusted channel. If not confirmed: reset password, revoke sessions and refresh tokens, review activity after E12.	F3	Owner response recorded; old tokens rejected.
A2	P1	Response	Review wider logs for stu-209, stu-415 and stu-502 for successful logins or password changes since 09:21 and notify the owners.	F2	No unexplained successes in the wider logs.
A3	P1	Response	Confirm whether the 09:22:01 block (E10) covers the whole IP or only stu-209; block or challenge 203.0.113.42 if it does not.	F2	A further attempt from the IP is refused.
A4	P2	Response	Confirm stu-117 recovered through a verified reset and that locks have a defined expiry and unlock path.	F1	Unlock path documented; no new failures.

ID	Pri	Type	Action	For	Verification
C1	P1	Rate limit	Add an IP-level counter independent of account: challenge or block an IP at >= 3 distinct accounts failing within 2 min, or >= 10 failures in 5 min.	F2	Replay and simulation: 5th account from the IP is refused.
C2	P2	Rate limit	Per account: progressive delay (3 failures -> 30 s, 5 -> 15 min soft-lock or step-up) instead of a hard lock when failures come from many IPs, to avoid lockout abuse.	F1, F2	Unit tests for each tier.
C3	P2	Rate limit	Enforce limits inline at the threshold crossing. Observed lag was 45 s (lock) and 39 s (rate limit), a window for extra attempts.	F1, F2	Lock/block logged within 1 s of the threshold event.
C4	P1	Rate limit	Require step-up (MFA or email confirmation) for logins from a new IP+device when the account had a failure in the last 24 h.	F3	Test login from a new pair prompts step-up.
C5	P3	Rate limit	Treat device='unknown' (no client identity) as a risk signal: stricter throttling.	F2	Unknown-device clients throttled in test.
D1	P1	Detection	Deploy rules R1-R4 as alerts with the severities above; keep this CSV as a regression test (expected: R1 stu-117, R2 203.0.113.42, R3 E12, nothing for stu-104).	F1-F3	Script reproduces expected alerts and no others.
D2	P2	Logging	Enrich logs: user agent, ASN/geo, session ID, MFA outcome, and for lock/block events the reason, scope and threshold. Log every blocked attempt.	F2, F3	New fields present in sample events.
D3	P2	Detection	Build a 30-day per-account baseline (known IP/device pairs, usual hours) and allow-list shared campus/NAT ranges for R2.	F3	Baseline job output; false-positive review.
D4	P3	Detection	Review alert precision monthly and tune thresholds; expect R1 to produce user-mistake false positives.	All	Monthly precision metric tracked.

9. Limitations and handling

- The log has no logout, MFA, page-access or password-change events, so what happened after the 11:47 login cannot be determined from it.
- One day and 12 events: findings describe patterns, not rates. Re-run the script on a larger log before trusting thresholds.
- Users are pseudonymous IDs and all IPs are documentation addresses; no secrets or personal data appear in this report.
- Analysis was done offline on the supplied file. No external system was scanned, probed or contacted.

Reproduce: **python src/investigation.py** *(prints rules and writes out/normalized_log.csv, out/findings.json), then* **python src/make_workbook.py** *and* **python src/make_report.py**.